AI Data-Exposure Assessment — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — AI Data-Exposure Assessment (Microsoft Purview) 4

What you get . . . 4

What this delivers . . . 4

The deployment model . . . 5

Outcome . . . 5

1. Solution Overview — AI Data-Exposure Assessment (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 5

What the assessment measures . . . 6

The scope of "outcomes" (what this solution does and does not decide) . . . 6

Naming convention (used in every doc and script) . . . 6

The standard deployment model . . . 7

2. Requirements Guide — AI Data-Exposure Assessment (Microsoft Purview) 7

2.1 Compliance / AI licensing (verify in your tenant) . . . 7

2.2 Least-privilege assessment roles and portal access . . . 8

2.3 Unified auditing turned on . . . 8

2.4 A labels + DLP baseline to measure exposure against . . . 8

2.5 Microsoft 365 Copilot / AI apps in scope . . . 8

2.6 SharePoint/OneDrive access & sharing signal . . . 8

2.7 Pilot scope and simulation discipline . . . 9

Global Requirements — Microsoft Purview Solutions 9

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 9

2. Purview roles (least-privilege) and portal access . . . 10

3. Security & Compliance PowerShell + Graph toolchain . . . 10

4. Data sources & scope in scope . . . 10

5. Compliance, records, privacy & legal stakeholders . . . 10

6. A pilot scope and change control . . . 11

3. Implementation Guide — AI Data-Exposure Assessment (Microsoft Purview) 11

Step 0 — Confirm scope, licensing, roles, auditing, and AI-in-scope (Assess) . . . 12

Step 1 — Discover the AI access surface and reachability (Assess → Design) . . . 12

Step 2 — Read the reachability in the portal and name the hotspots (Assess) . . . 13

Step 3 — Rank the priority exposure risks (Design) . . . 13

Step 4 — Validate the recommended fix path in SIMULATION (Configure → Pilot) . . . 13

Step 5 — Validate the assessment and confirm the simulation-only posture (Validate) . . . 14

Step 6 — Hand off the defensible baseline and set a re-assessment cadence (Expand → handoff) 14

5. Testing Guide — AI Data-Exposure Assessment (Microsoft Purview) 15
Test 1 — Environment, licensing, roles, auditing, and AI-in-scope . . . 15
Test 2 — Access-surface inventory is complete . . . 15
Test 3 — Sensitive-type scope is captured . . . 15
Test 4 — Reachability signal populates . . . 15
Test 5 — Oversharing hotspots are identifiable . . . 15
Test 6 — Risk register ranks the priority exposure . . . 15
Test 7 — Pilot helper makes no change in dry-run . . . 16
Test 8 — Pilot policy is created in SIMULATION only . . . 16
Test 9 — Simulation results confirm the fix path (validation gate) . . . 16
Test 10 — Assessment evidence is complete and consistent . . . 16
Test 11 — Rollback works . . . 16
6. Troubleshooting Guide — AI Data-Exposure Assessment (Microsoft Purview) 16
DSPM for AI blade is not visible . . . 17
`AIEXPOSE-ScopeCheck.ps1` reports the S&C; session as FAIL . . . 17
The AI-interaction signal is empty . . . 17
`Search-UnifiedAuditLog` returns nothing or errors . . . 17
The oversharing / broad-sharing export is empty but you expect sharing . . . 17
Discovery shows a thin taxonomy / no DLP . . . 18
`AIEXPOSE-RiskRegister.ps1` produces an empty register . . . 18
Auto-labeling cmdlet fails as "not recognized" / access denied . . . 18
The pilot policy landed in an enforcing mode . . . 18
Simulation results show too many would-be labels (false positives) . . . 18
The assessment "changed" something . . . 18
Escalation boundary . . . 19
7. Best Practices — AI Data-Exposure Assessment (Microsoft Purview) 19
8. Deliverables Summary — AI Data-Exposure Assessment (Microsoft Purview) 20
Documentation . . . 20
PowerShell scripts . . . 21
What the buyer receives . . . 22
Outcome . . . 22
Appendix A — PowerShell Scripts 23

Executive Summary — AI Data-Exposure Assessment (Microsoft Purview)

Before you turn on Microsoft 365 Copilot — or any enterprise AI that reads your tenant — one question decides whether you are ready: **what could it expose?** Copilot surfaces any content a user already has access to, so years of over-shared, unlabeled files that "nobody ever found" become one prompt away. This solution is a repeatable, self-guided **assessment** that answers the question with evidence: it scopes what AI/Copilot could access, measures the reachability, and quantifies the priority risks into a ranked, defensible **Exposure Risk Register** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph, no third-party tooling.

It is deliberately an assessment, not a remediation program. It delivers the *measurement and the evidence* so an organization can make an informed, defensible decision about AI adoption. The single change it makes is **piloted in simulation** — an auto-labeling policy that labels *nothing*, only proving the recommended fix would land on the right content. Standing up an enforced reduction program is a separate, change-controlled follow-on.

What you get

- A plain-language Solution Overview of what the assessment measures — the AI access surface, reachability,

priority risk, and fix-path validation — the availability/licensing caveat for these evolving features, and the boundaries between assessment and remediation, and between technical method and legal/records determination.

- A Requirements Guide with verify / implement-if-missing for every prerequisite — licensing,

least-privilege roles, auditing, the labels + DLP baseline, Copilot/AI in scope, the sharing signal, and simulation discipline.

- An Implementation Guide of precise, ordered portal and PowerShell steps: confirm scope, discover the

access surface, measure reachability, rank the priority risks, validate the fix in simulation, validate the evidence, hand off the baseline, and set a re-assessment cadence.

- Five PowerShell scripts for scope/health checking, access-surface discovery, reachability reporting,

risk-register ranking, and safe fix-path validation (read-only or `-WhatIf`/simulation by default — never enforcing).

- Testing and Troubleshooting guides, with an explicit simulation validation gate, for a confident, safe

assessment.

What this delivers

A measured AI-access-surface inventory, a reachability report of what Copilot/AI could reach and — where AI is in use — what it has touched, a scored and ranked **Exposure Risk Register** of the priority risks, and a **simulation-validated** recommended fix path — every step read-only or simulation, changing no content — so the exposure picture is defensible and the fix decision is de-risked.

The deployment model

Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce, handed off as a follow-on).

Outcome

AI data exposure made visible, quantified, and defensible — the access surface inventoried, reachability measured, priority risks ranked, and the recommended fix validated in simulation — so an organization can decide on AI adoption with evidence rather than hope. Feature availability is flagged to verify in your tenant; regulatory, records, and legal determinations remain with your governance functions.

1. Solution Overview — AI Data-Exposure Assessment (Microsoft Purview)

What this solution is

Before you turn on Microsoft 365 Copilot — or any enterprise AI that reads your tenant — you need one answer: **what could it expose?** Copilot surfaces any content a user already has access to, so years of over-shared, unlabeled files that "nobody ever found" become one prompt away. This solution is a repeatable, self-guided **assessment** that answers the question with evidence: it **scopes what AI/Copilot could access, measures the reachability, and quantifies the priority risks** into a ranked, defensible **Exposure Risk Register** — using only the Microsoft Purview portal, Security & Compliance PowerShell (`Connect-IPPSSession`), and Microsoft Graph, with no third-party tooling.

It is deliberately an **assessment**, not a remediation program. It produces the *measurement and the evidence* — the exposure baseline, the ranked risks, and a validation that the recommended fix path works — so an organization can make an informed, defensible decision about AI adoption. The one change it makes is **piloted in simulation** (an auto-labeling policy that labels *nothing*, only reporting what it *would* label) purely to prove the fix path; standing up an enforced reduction program is a separate follow-on.

Why this matters

- **Exposure is invisible by default.** Sensitive data is scattered across SharePoint, OneDrive, Teams, and

Exchange, much of it unlabeled and broadly shared. Nobody can say how much of it AI could reach — until it is measured.

- **Generative AI changes the blast radius.** A file "technically shared with everyone but never opened"

is inert until Copilot can surface it to anyone with access. The assessment makes that reachability measurable *before* it becomes an incident.

- **A decision needs a baseline.** "Are we ready for Copilot?" is unanswerable without a quantified

exposure picture. This solution delivers that baseline and a prioritized risk register you can defend.

- **The fix must be provable, not guessed.** Rather than assert "labeling will fix this," the assessment

validates the recommended remediation in simulation — proving it would land on the right content without changing anything.

What the assessment measures

- **AI access surface (Discovery)** — the sensitivity labels, label-publishing scope, DLP, and

auto-labeling that *bound* what can be protected or kept out of AI. A thin taxonomy or narrow DLP scope is itself the first exposure finding.

- **Reachability (Assess)** — the two exposure signals: **oversharing** (SharePoint/OneDrive content shared

organization-wide / with "everyone" / via anonymous links, which Copilot can surface to anyone with access) and **AI-interaction activity** from the unified audit log (what AI has actually touched, where Copilot is already in use).

- **Priority risk (Rank)** — a transparent, deterministic **exposure score** (reachability breadth × the

sensitivity/lever signal) that sorts the broadly-shared, sensitive-data-likely, AI-reachable content to the top of the **Exposure Risk Register**.

- **Fix-path validation (Pilot in simulation)** — a single recommended remediation validated in

simulation mode to confirm it would work, with no content changed and nothing enforced.

> ***Feature availability & licensing — verify in your tenant.*** *DSPM for AI, auto-labeling, advanced DLP, and the site-access controls are **licensing-/plan-dependent** (commonly **Microsoft 365 E5** or the **E5 Compliance** add-on; some need **SharePoint Advanced Management** and/or a **Microsoft 365 Copilot** license) and the Purview portal is **actively evolving**. Treat the specific blades, cmdlets, and audit record types in this guide as a current-state map to **confirm against your own tenant**, never as guaranteed. This solution flags where to verify rather than asserting availability.*

The scope of "outcomes" (what this solution does and does not decide)

This solution delivers the **technical method and the evidence** — how to scope, measure, and rank AI data exposure, and a validated fix path. It does **not** make **regulatory, records, or legal determinations**. *Which* risks must be remediated, *what* AI-exposure level is acceptable, and any records/legal-hold obligations are **deferred to your compliance, records, privacy, and legal functions**. You provide the quantified exposure and the evidence; they own the determination.

Naming convention (used in every doc and script)

Every artifact this solution creates or exports is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal so a reader can trace one artifact end to end.

Artifact	Name
Scope/readiness export	`AIEXPOSE Scope Check – Estate – Assess`
AI access-surface inventory	`AI Access Scope – Estate – Discovery`
Sensitive-info-type scope export	`Sensitive Exposure – Estate – Assess`

Artifact	Name
AI/Copilot reachability report	`AI Reachability – Copilot – Assess`
Broad-access/oversharing export	`Oversharing Exposure – Sites – Assess`
Prioritized exposure risk register	`Exposure Risk Register – Estate – Rank`
Pilot fix-path validation (simulation) policy	`Exposure Remediation – Pilot – Simulation`
Recurring re-assessment cadence tag	`AI Exposure Re-Assessment – Estate – Recurring`

The standard deployment model

> *Confirm scope → discover the AI access surface → measure reachability → rank the priority risks → validate the recommended fix in **simulation** → hand a defensible baseline + register to the governance functions → re-assess on a recurring cadence. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce).** Here "Expand (enforce)" is deliberately handed off — the assessment validates the fix path; enforcing it is a separate, change-controlled follow-on.*

2. Requirements Guide — AI Data-Exposure Assessment (Microsoft Purview)

Verify **every** requirement before assessing. Each entry gives **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, stakeholders, pilot/change-control) are in `global-requirements-purview.md` — this guide adds the exposure-assessment-specific prerequisites.

> ***Availability caveat.** DSPM for AI, auto-labeling, advanced DLP, and site-access controls are evolving, licensing-/tenant-dependent capabilities whose blades, cmdlets, and audit record types change. Where this guide names a portal path, cmdlet, or audit RecordType, **confirm it exists in your tenant** rather than assuming — several requirements below are "verify in your tenant" by design.*

2.1 Compliance / AI licensing (verify in your tenant)

Description: The compliance licensing the assessment relies on — commonly **Microsoft 365 E5** or the **E5 Compliance** add-on for advanced DLP, auto-labeling, and the DSPM-for-AI reports; some AI-exposure and site-access controls may additionally require **SharePoint Advanced Management** and/or a **Microsoft 365 Copilot** license. The assessment can run on a licensed subset — it notes any absent capability rather than failing. **Why:** The reachability signal and the fix-path validation lean on plan-gated features (auto-labeling, advanced DLP, DSPM for AI); their presence bounds what can be measured and validated. **Verify:** In the M365 admin center confirm the subscriptions/add-ons; in the Purview portal (`https://purview.microsoft.com`) confirm **DSPM for AI** is visible. Run `AIEXPOSE-ScopeCheck.ps1` (read-only) to enumerate the licensing-dependent features present. **Implement:** Assign/purchase the required licensing before starting; where a capability is absent, note it out of scope and assess the licensed subset.

2.2 Least-privilege assessment roles and portal access

Description: Membership in the least-privilege Purview role group(s) needed to **read** posture and configuration — typically an information-protection / compliance-reader-capable role group — plus, only for the simulation fix-path validation, the role that can **create an auto-labeling policy in simulation**. Confirm the **exact current role-group names** in your portal. **Why:** Purview uses fine-grained role groups; reading labels/DLP/reachability and creating a simulation policy each need the matching role, and separation of duties should be preserved (reading exposure ≠ changing enforcement). **Verify:** Purview portal → **Settings / Roles & scopes** → **Role groups** — confirm your account's membership; confirm you can open **DSPM for AI** without an access error. **Implement:** Assign the least-privilege role group under change control; reserve Global/Compliance Administrator for the initial enablement only.

2.3 Unified auditing turned on

Description: Purview **Audit** (the unified audit log) enabled tenant-wide, since the AI-interaction signal and the broad-sharing signal are sourced from audit records. **Why:** Without auditing on, the "what has AI actually touched" and "what was shared broadly" signals are empty or incomplete, weakening the reachability measurement. **Verify:** Purview portal → **Audit** shows searching is on; `AIEXPOSE-ScopeCheck.ps1` reports `UnifiedAuditLogIngestionEnabled`. AI-interaction records should be present once Copilot/AI has been used. **Implement:** Turn on auditing (a one-time tenant action); allow time for records to accumulate before expecting AI-interaction reports to populate.

2.4 A labels + DLP baseline to measure exposure against

Description: At least a **baseline of sensitivity labels and DLP** in place (or ready to create), because the assessment measures exposure *relative to* the protection that exists and validates a fix that acts *through* labels and DLP. **Why:** Label coverage and DLP scope bound how much exposure can be reduced; their absence is itself a top-of-register finding (the register adds a no-lever penalty when no DLP exists). **Verify:** Purview portal → **Information Protection** → **Labels** and **Data Loss Prevention** → **Policies**; `AIEXPOSE-Discovery.ps1` inventories labels, label policies, DLP policies/rules, and auto-labeling policies. **Implement:** A thin or absent taxonomy/DLP is a valid finding — record it. A dedicated sensitivity-labels or DLP solution stands up the baseline that any recommended fix would use.

2.5 Microsoft 365 Copilot / AI apps in scope

Description: Clarity on which AI is in scope — **Microsoft 365 Copilot**, Copilot experiences, and/or other **enterprise AI apps** — and whether it is licensed and in use, so the assessment is framed correctly as **pre-adoption** (measure exposure before turning AI on) or **in-adoption** (measure what AI already touches). **Why:** The value pivots on this: pre-adoption, the assessment quantifies risk to inform the go/no-go; in-adoption, it also reads the AI-interaction signal of actual contact with sensitive data. **Verify:** Confirm Copilot/AI licensing and rollout status with the owning team; Purview portal → **DSPM for AI** shows connected AI activity once present. `AIEXPOSE-ScopeCheck.ps1` probes whether AI-interaction audit records exist. **Implement:** Confirm the AI in scope with stakeholders; if Copilot is not yet deployed, run the assessment in **pre-adoption** mode — the oversharing signal is still the exposure to quantify before enabling AI.

2.6 SharePoint/OneDrive access & sharing signal

Description: The ability to read **site/file access and sharing** state — the "oversharing" that makes content reachable by AI — from the unified audit log and/or Microsoft Graph, and (for the strongest site-access controls that a fix might later use) **SharePoint Advanced Management** (verify licensing). **Why:** Reachability scoring targets broadly-shared and organization-wide-accessible content; measuring it needs the sharing/access signal, and the sharing Operations that surface it evolve. **Verify:** `AIEXPOSE-Discovery.ps1` reports the broad-sharing signal from the audit log (Operations are parameterized); confirm whether SharePoint Advanced Management site-access controls are available in your tenant. **Implement:** Where the advanced site-access controls are unavailable, the register still ranks the oversharing targets; site-owner sharing reviews and the label + DLP levers are the reduction path a follow-on would use.

2.7 Pilot scope and simulation discipline

Description: A named **pilot scope** (a ring of users/sites) and the intent to validate the recommended fix **only in simulation** — the assessment's single change is an auto-labeling policy in **simulation mode** that labels nothing (as the category model requires, GR §6). Enforcement is explicitly out of scope for the assessment. **Why:** Even fix-path validation must not disturb real content; simulation surfaces whether the fix would land correctly before anyone commits to enforcing it. **Verify:** Confirm the pilot ring, that auto-labeling **simulation mode** is available, and that a change window/approval exists for creating the simulation policy. **Implement:** Define the pilot and the change-control path before creating the simulation policy; the scripts default to `-WhatIf` and create the policy in simulation only — they never enforce.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — AI Data-Exposure Assessment (Microsoft Purview)

Follow these steps **in order**. Posture and reports are read in the **Microsoft Purview portal** (`https://purview.microsoft.com`); the access-surface inventory, reachability signal, risk ranking, and the simulation fix-path validation are automated with Security & Compliance PowerShell (`Connect-IPPSSession`) and Microsoft Graph. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **The one change this assessment makes is piloted in simulation** — the pilot script defaults to `-WhatIf` and creates the auto-labeling policy in simulation only; it never enforces.

> ***Model:*** *Confirm scope, discover the AI access surface, measure reachability, rank the priority risks, validate the recommended fix in simulation, hand a defensible baseline + register to the governance functions, and re-assess on a recurring cadence. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand (enforce)*** *— where "Expand (enforce)" is handed off, not performed by the assessment.* ***Portal-path caveat.*** *DSPM for AI blades, cmdlets, and audit record types are evolving; the paths and record types below are the current map. If a blade, cmdlet, or RecordType differs in your tenant, use the closest equivalent and* ***confirm before acting*** *— the scripts*

parameterize the volatile values so you can override rather than assume.

Step 0 — Confirm scope, licensing, roles, auditing, and AI-in-scope (Assess)

1. Run `AIEXPOSE-ScopeCheck.ps1` (read-only). It confirms your `Connect-IPPSSession`/`Connect-MgGraph`

sign-in, reports whether **auditing** is on, enumerates the licensing-dependent controls (labels, DLP, auto-labeling), and probes whether **Copilot/AI interaction records** exist — resolving Requirements 2.1–2.5. Writes `AIEXPOSE Scope Check – Estate – Assess`.

1. In the Purview portal confirm **DSPM for AI** is visible (Requirement 2.1/2.5). Note any absent

capability so you scope around it.

1. Decide the framing: **pre-adoption** (no Copilot yet) or **in-adoption** (Copilot in use), and confirm

the **pilot ring** and change window (Requirement 2.7) for the later simulation step.

Pass/fail: Sign-in succeeds, auditing is on, DSPM for AI is visible, framing and pilot scope agreed. **Rollback:** None — read-only.

Step 1 — Discover the AI access surface and reachability (Assess → Design)

1. Connect both sessions: `Connect-IPPSSession` (access surface) and `Connect-ExchangeOnline` (the audit

log that feeds the reachability signal). Run `AIEXPOSE-Discovery.ps1 -Days 30` (read-only). It:

• inventories **sensitivity labels**, **label policies** (publishing scope), **DLP policies/rules**, and

auto-labeling policies via S&C PowerShell → `AI Access Scope – Estate – Discovery`; and

• measures reachability from the unified audit log — **AI/Copilot interaction** activity →

`AI Reachability – Copilot – Assess`, and the **broad-sharing** signal grouped by site → `Oversharing Exposure – Sites – Assess`. If your tenant's AI RecordType or sharing Operations differ, override with `-AiRecordType` / `-SharingOperations`.

1. Add `-IncludeSensitiveTypes` to append the **sensitive information types** in scope to

`Sensitive Exposure – Estate – Assess` — a portable record of what "sensitive" means in your tenant.

1. Review against Requirement 2.4: a thin taxonomy or narrow DLP scope is the **first exposure finding** —

it caps how much any fix could reduce, and the register will weight it.

Pass/fail: The inventory lists your labels, label policies, DLP policies/rules, and auto-labeling policies; the two reachability exports and (with the switch) the sensitive-type export are written. **Rollback:** None — read-only.

Step 2 — Read the reachability in the portal and name the hotspots (Assess)

1. Purview portal → **DSPM for AI** → **Reports**: review the AI **data-access / oversharing** view (what AI

can reach) and, if Copilot is in use, the **sensitive interactions** view (prompts/responses referencing sensitive data). These are the two exposure questions: *what can AI reach* and *what has AI touched* — the same two signals `AIEXPOSE-Discovery.ps1` exported in Step 1.

1. Cross-read `Oversharing Exposure – Sites – Assess` with the portal data-access view: broadly-shared sites

likely holding **unlabeled sensitive** content are the priority reachability targets.

1. Pre-adoption, the AI-interaction set may be empty — expected. The **oversharing signal is still the

pre-adoption exposure** to quantify before enabling Copilot.

Pass/fail: The oversharing hotspots are visible by site and named as the priority set. **Rollback:** None — read-only.

Step 3 — Rank the priority exposure risks (Design)

1. Run `AIEXPOSE-RiskRegister.ps1` (read-only). It reads the discovery inventory and the oversharing export

and produces the ranked `Exposure Risk Register – Estate – Rank` — each site scored by reachability breadth (broad-share events) with a **no-lever penalty** when no DLP exists to protect content, sorted highest exposure first. Each row carries a **Rationale** and a **suggested fix family** (restrict sharing / apply label / scope DLP-for-AI).

1. The score is **decision support, not a determination.** With compliance/records/privacy/legal (GR §5),

review the register and agree which top risks are candidates for remediation and what AI-exposure level is acceptable. **The determination is theirs**; you provide the ranked evidence.

Pass/fail: The register is written, ranked, and reviewed with stakeholders; the candidate top risks are recorded. **Rollback:** None — read-only.

Step 4 — Validate the recommended fix path in SIMULATION (Configure → Pilot)

Validate that the recommended fix for a top risk *would work*, without changing any content. This is the assessment's only change and it is **simulation only**.

1. **Dry-run first.** Run

`AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -WhatIf` (the default). It prints the policy it *would* create and changes nothing.

1. **Create the simulation policy.** Re-run with `-Commit`. With `-Commit` it creates the auto-labeling

policy `Exposure Remediation – Pilot – Simulation` in **simulation mode** (`TestWithoutNotifications`) — it labels *nothing*, it only reports what it *would* label. Add a matching auto-labeling **rule** with your sensitive-info-type conditions, then review the **simulation results** in the portal to confirm the fix would land on the right content.

1. **Sharing targets (no policy).** Run

`AIEXPOSE-PilotRemediation.ps1 -Action SharingTargets -RiskRegisterCsv .\AIEXPOSE-RiskRegister-Estate-Rank.csv` to produce the prioritized site list for site-owner sharing review. The script **does not** change sharing — it only produces the target list for a change-controlled follow-on.

Pass/fail: The pilot policy exists in **simulation** (labels nothing); the sharing target list is produced — nothing is enforced, no content changed. **Rollback:** Delete the simulation policy (it enforces nothing and changed no content).

Step 5 — Validate the assessment and confirm the simulation-only posture (Validate)

1. Run `AIEXPOSE-Validate.ps1` (read-only). It confirms all expected exports exist and are consistent

(scope check, discovery, reachability, oversharing, and a descending-ranked register) and — if the pilot policy was created — confirms it is in **simulation** mode and enforces nothing. Writes `AIEXPOSE Validate – Estate – Assess`.

1. In the portal, review the auto-labeling **simulation results** for the pilot: the would-be labels should

match intent (an acceptable false-positive rate) — this is the evidence the fix path is sound. See Testing (doc 5) for the explicit gates.

1. If any validation check is **FAIL** (a missing export, or a policy found in an enforcing mode), correct

it before hand-off. A pilot policy in any non-simulation mode is a stop condition.

Pass/fail: All exports present and consistent; the pilot policy (if present) is confirmed simulation-only. **Rollback:** Return any non-simulation policy to `TestWithoutNotifications` or delete it.

Step 6 — Hand off the defensible baseline and set a re-assessment cadence (Expand → handoff)

1. Package the deliverables — `AI Access Scope – Estate – Discovery`, `AI Reachability – Copilot – Assess`,

`Oversharing Exposure – Sites – Assess`, and the ranked `Exposure Risk Register – Estate – Rank` — as the defensible AI-exposure baseline for the governance functions to decide against.

1. **Enforcement is explicitly a follow-on.** Turning the validated fix into an enforced reduction program

(auto-labeling on, DLP-for-AI enforcing, sharing restrictions applied at scope) is a separate, change-controlled engagement — not part of this assessment. The simulation validation de-risks that decision.

1. Stand up the recurring re-assessment: tag the cadence `AI Exposure Re-Assessment – Estate – Recurring`

and schedule the read-only `ScopeCheck → Discovery → RiskRegister` chain (e.g. monthly or before each AI rollout wave) so exposure stays measured as data and AI usage change.

Pass/fail: Baseline + register handed off; enforcement scoped as a follow-on; recurring re-assessment scheduled. **Rollback:** None — read-only handoff; the simulation policy, if kept, remains simulation-only.

5. Testing Guide — AI Data-Exposure Assessment (Microsoft Purview)

Run these after each stage. Every test is safe (read-only or simulation); the simulation review is the **gate** that proves the recommended fix path is sound *before* anyone commits to enforcing it. Pass/fail is explicit.

Test 1 — Environment, licensing, roles, auditing, and AI-in-scope

Do: Run `AIEXPOSE-ScopeCheck.ps1`; open **DSPM for AI** in the Purview portal. **Expected:** Sign-in succeeds; auditing reports as **on**; DSPM for AI loads without an access error; the licensing-dependent controls are enumerated; the AI-interaction probe reports records present (in-adoption) or none (pre-adoption). Any absent capability is noted, not assumed. **Gate:** Do not proceed until DSPM for AI is visible and auditing is on.

Test 2 — Access-surface inventory is complete

Do: Run `AIEXPOSE-Discovery.ps1`; compare against **Information Protection** → **Labels** and **DLP** → **Policies** in the portal. **Expected:** `AI Access Scope – Estate – Discovery` lists every sensitivity label, label policy, DLP policy/rule, and auto-labeling policy shown in the portal — the baseline of protection exposure is measured against.

Test 3 — Sensitive-type scope is captured

Do: Run `AIEXPOSE-Discovery.ps1 -IncludeSensitiveTypes`. **Expected:** `Sensitive Exposure – Estate – Assess` records the in-scope sensitive information types — a portable record of what "sensitive" means in the tenant to accompany the assessment.

Test 4 — Reachability signal populates

Do: Run `AIEXPOSE-Discovery.ps1 -Days 30` (with Exchange Online connected); open **DSPM for AI** → **Reports**. **Expected:** `AI Reachability – Copilot – Assess` and `Oversharing Exposure – Sites – Assess` are written; the portal AI data-access view renders. *Note:* AI-interaction reporting depends on auditing being on (Test 1) and on Copilot/AI usage having occurred — pre-adoption, the AI-interaction set is legitimately empty while the oversharing signal is still present.

Test 5 — Oversharing hotspots are identifiable

Do: Cross-read `Oversharing Exposure – Sites – Assess` with the AI data-access view. **Expected:** You can name the top oversharing sites — broadly-shared locations likely to hold unlabeled sensitive content — as the priority reachability set.

Test 6 — Risk register ranks the priority exposure

Do: Run `AIEXPOSE-RiskRegister.ps1`. **Expected:** `Exposure Risk Register – Estate – Rank` is written, sorted highest exposure first, each row carrying a Score, a Rationale, and a suggested fix family. An empty register is a valid pre-adoption result (no broad-sharing signal in the window), not a failure.

Test 7 — Pilot helper makes no change in dry-run

Do: Run `AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -WhatIf`; then re-run `AIEXPOSE-Discovery.ps1`. **Expected:** The dry-run prints the intended simulation policy it *would* create; the discovery inventory is unchanged — `-WhatIf` created nothing. **This is the gate that proves the helper is safe by default.**

Test 8 — Pilot policy is created in SIMULATION only

Do: Run the helper with `-Commit` (`AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -Commit`); inspect the policy `Exposure Remediation – Pilot – Simulation` in the portal and via `AIEXPOSE-Validate.ps1`. **Expected:** The auto-labeling policy is in **simulation** mode (`TestWithoutNotifications`) and labels nothing. No content is changed. **Gate:** If the policy landed in any enforcing mode, stop and correct (return to `TestWithoutNotifications` or delete) before continuing — this assessment never enforces.

Test 9 — Simulation results confirm the fix path (validation gate)

Do: Add the matching auto-labeling rule; let the simulation evaluate; review the **simulation results** in the portal for false positives; confirm with stakeholders. **Expected:** The would-be labels match intent with an acceptable false-positive rate — evidence the recommended fix would land on the right content. **Gate:** This is the evidence that de-risks a future enforcement decision. Enforcement itself remains a separate follow-on; the assessment stops here.

Test 10 — Assessment evidence is complete and consistent

Do: Run `AIEXPOSE-Validate.ps1`. **Expected:** `AIEXPOSE Validate – Estate – Assess` reports PASS for every expected export (scope check, discovery, reachability, oversharing, register), the register is in descending score order, and any pilot policy is confirmed simulation-only. Any FAIL (missing export or a non-simulation policy) is corrected before hand-off.

Test 11 — Rollback works

Do: On the pilot simulation policy, exercise the documented rollback (delete it). **Expected:** The policy is removed with no residual content change — the assessment changed nothing but the one simulation policy, which enforced nothing.

6. Troubleshooting Guide — AI Data-Exposure Assessment (Microsoft Purview)

Field issues and fixes. Most stem from **licensing/availability** (these features are evolving and plan-gated), **auditing being off**, the AI simply **not having been used yet** (a legitimate pre-adoption state), or a

tenant-specific audit RecordType / sharing Operation that differs from the default. When a portal path or cmdlet differs from this guide, confirm the current equivalent rather than assuming.

DSPM for AI blade is not visible

- **Likely cause:** Licensing (Requirement 2.1) or role membership (Requirement 2.2).
- **Fix:** Confirm the subscription/add-ons in the M365 admin center; confirm your account is in a

DSPM-for-AI-capable role group in Purview → Roles & scopes. Run `AIEXPOSE-ScopeCheck.ps1` to enumerate what your session can see. If the capability is genuinely absent for your plan, scope around it and note it — the reachability signal from the audit log still supports the assessment.

`AIEXPOSE-ScopeCheck.ps1` reports the S&C session as FAIL

- **Cause:** Not connected to Security & Compliance PowerShell.
- **Fix:** `Connect-IPPSSession` with a modern-auth/MFA admin (GR §3). Re-run. For the auditing check and

`Search-UnifiedAuditLog`, also connect Exchange Online (`Connect-ExchangeOnline`).

The AI-interaction signal is empty

- **Cause 1 — pre-adoption:** With no Copilot/AI usage there is nothing to report yet. **Fix:** This is

expected — the assessment is in **pre-adoption** mode; use the oversharing signal (`AIEXPOSE-Discovery.ps1` broad-sharing events) to quantify exposure *before* enabling AI.

- **Cause 2 — auditing off:** AI-interaction and sharing signal is sourced from the unified audit log.

Fix: Turn auditing on (Requirement 2.3); `AIEXPOSE-ScopeCheck.ps1` shows `UnifiedAuditLogIngestionEnabled`. Allow time for records to accumulate.

- **Cause 3 — wrong audit RecordType:** The record type that surfaces AI/Copilot interactions evolves.

Fix: Confirm the current value in Purview → Audit and pass it via `-AiRecordType`.

`Search-UnifiedAuditLog` returns nothing or errors

- **Cause:** Not connected to Exchange Online, auditing off, or the window predates auditing being on.
- **Fix:** `Connect-ExchangeOnline`; confirm auditing on; widen `-Days` within the retained window. Note

audit data has ingestion latency — very recent activity may not appear yet.

The oversharing / broad-sharing export is empty but you expect sharing

- **Cause:** The default sharing **Operations** don't match what your tenant logs, or the window is too

short.

- **Fix:** Confirm the current sharing Operations in Purview → Audit and pass them via `-SharingOperations`;

widen `-Days`. The script parameterizes these precisely because they evolve — it does not assume them.

Discovery shows a thin taxonomy / no DLP

- **This is a finding, not an error.** Label coverage and DLP scope bound how much exposure a fix could

reduce; their absence raises exposure. `AIEXPOSE-RiskRegister.ps1` applies a **no-lever penalty** when no DLP exists so this surfaces at the top of the register. Record it as a top recommendation, not a script failure.

`AIEXPOSE-RiskRegister.ps1` produces an empty register

- **Cause:** No broad-sharing signal in the window (often genuine pre-adoption), or the reachability export

wasn't produced.

- **Fix:** Confirm `AIEXPOSE-Discovery.ps1` ran (with Exchange Online connected) and wrote `Oversharing Exposure – Sites – Assess`; widen

the reachability `-Days`. An empty register can be a valid result — `AIEXPOSE-Validate.ps1` reports it as a WARN (pre-adoption), not a FAIL.

Auto-labeling cmdlet fails as "not recognized" / access denied

- **Cause:** Auto-labeling is unlicensed, or the role lacks the (simulation) policy-creation right.
- **Fix:** Confirm licensing (Requirement 2.1) and the configuration role (Requirement 2.2). Reading is

possible with a lower role than creating; if you cannot create the simulation policy, the assessment can still hand off the ranked register and validate the fix path later once the role/licensing is in place.

The pilot policy landed in an enforcing mode

- **Cause:** Wrong mode or a manual portal change.
- **Fix:** `AIEXPOSE-PilotRemediation.ps1` creates auto-labeling only in **simulation**

(`TestWithoutNotifications`) by design and never enforces. If a policy is enforcing, return it to simulation (`Set-AutoSensitivityLabelPolicy -Mode TestWithoutNotifications`) or delete it. `AIEXPOSE-Validate.ps1` flags any non-simulation mode as a **FAIL** — this assessment does not enforce.

Simulation results show too many would-be labels (false positives)

- **Cause:** The auto-labeling rule conditions (sensitive-info-type confidence, scope) are too broad.
- **Fix:** Tighten the rule conditions and re-simulate. The simulation exists precisely to tune the fix

path before anyone decides to enforce it — that tuning is part of validating the recommendation, not a defect.

The assessment "changed" something

- **It should not have.** Every script is read-only except `AIEXPOSE-PilotRemediation.ps1`, which requires

`-Commit` and only ever creates a **simulation** policy that labels nothing. If you believe content changed, run `AIEXPOSE-Validate.ps1` and confirm the pilot policy mode; delete the simulation policy to return to a fully read-only state.

Escalation boundary

Regulatory, records-retention, and legal questions — *which* risks must be remediated, what AI-exposure level is acceptable, legal-hold implications — are **not** resolved here. Capture the technical evidence (the exports and the ranked register) and route the determination to your compliance, records, privacy, and legal functions (GR §5). Enforcing a validated fix is a separate, change-controlled follow-on, not part of this assessment.

7. Best Practices — AI Data-Exposure Assessment (Microsoft Purview)

- **Assess *before* you turn on Copilot.** The whole point is a decision-quality baseline ahead of AI

adoption. A file Copilot can't reach can't be surfaced by a prompt — quantify the reachable-and-sensitive intersection first, then decide.

- **Measure reachability, not just protection.** Label and DLP coverage tell you what's *protected*;

oversharing and AI-interaction signal tell you what's *reachable*. Exposure lives at the intersection — broadly-shared, unlabeled, sensitive content. Rank on that, not on the easiest-to-fix tickets.

- **The register is evidence, not a verdict.** The exposure score ranks findings for human review; *which*

risks to remediate and *what* AI-exposure level is acceptable are compliance/records/privacy/legal calls. Hand over the ranked evidence; let them own the determination (GR §5).

- **Validate the fix path in simulation — never enforce in the assessment.** Prove the recommended

remediation would land correctly by running auto-labeling in **simulation** (`TestWithoutNotifications`), which labels nothing. `-WhatIf` is the default on the pilot helper for the same reason — read every intended action before you `-Commit`. Enforcing a validated fix is a separate, change-controlled follow-on.

- **Treat a thin taxonomy or absent DLP as a top finding.** If there is no lever to protect content, every

reachable-sensitive site is more exposed — the register applies a no-lever penalty precisely so this surfaces. Investing in labels/DLP is often the highest-leverage recommendation.

- **Verify availability, never assume it.** DSPM for AI, auto-labeling, advanced DLP, and the audit record

types are evolving and licensing-dependent. When a blade, cmdlet, or RecordType isn't where this guide says, confirm it in your tenant and override the script's parameter — don't force a path that isn't there.

- **Keep auditing on.** The AI-interaction and broad-sharing signals are only as complete as the unified

audit log feeding them. If the signal looks empty, check auditing and confirm AI usage has actually occurred — pre-adoption emptiness is expected and not a failure.

- **Parameterize the volatile values.** The AI RecordType and sharing Operations differ across tenants and

change over time; pass `-AiRecordType` / `-SharingOperations` after confirming the current values rather than trusting a default blindly.

- **Preserve separation of duties.** Read exposure with a least-privilege reader role; keep the (simulation)

policy-creation right separate. Reserve Global/Compliance Administrator for initial enablement only.

- **Make re-assessment recurring.** Data and AI usage drift, and each AI rollout wave changes the picture.

Schedule the read-only `ScopeCheck → Discovery → RiskRegister` chain under `AI Exposure Re-Assessment – Estate – Recurring` so exposure is measured continually, not once.

- **Keep the assessment reproducible.** Retain the exports and the register as the dated baseline; the next

re-assessment compares against it to show whether exposure is trending down as fixes are (separately) applied.

8. Deliverables Summary — AI Data-Exposure Assessment (Microsoft Purview)

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What the assessment measures (AI access surface, reachability, priority risk, fix-path validation), the availability/licensing caveat, the assessment-vs-remediation boundary, the outcome-vs-determination boundary, and the naming convention
2. Requirements Guide	Every exposure-assessment prerequisite with Verify / Implement-if-missing (licensing, least-privilege roles, auditing, labels+DLP baseline, Copilot/AI in scope, sharing signal, simulation discipline)
Global Requirements (Purview)	Category-wide prerequisites, published once

Document	Purpose
3. Implementation Guide	Exact, ordered portal + PowerShell steps: confirm scope, discover the access surface, measure reachability, rank the priority risks, validate the fix in simulation, validate the evidence, hand off the baseline, set a re-assessment cadence
5. Testing Guide	Validation procedures with explicit pass/fail and the simulation validation gate
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations for measuring and ranking exposure safely

PowerShell scripts

All are safe-by-default (read-only, or `-WhatIf` / simulation unless `-Commit` — and even then simulation only, never enforcing), use `Connect-IPPSSession` and/or `Connect-MgGraph`, and store **no** credentials.

Script	What it does
`AIEXPOSE-ScopeCheck.ps1`	Read-only scope/health helper: confirms sign-in, reports whether **auditing** is on, enumerates the licensing-dependent controls (labels, DLP, auto-labeling), and probes for Copilot/AI interaction records. Writes `AIEXPOSE Scope Check – Estate – Assess`. Resolves Requirements 2.1–2.5
`AIEXPOSE-Discovery.ps1`	Read-only discovery of the AI access surface **and** reachability. Inventories sensitivity labels, label policies, DLP policies/rules, auto-labeling policies (and, with `-IncludeSensitiveTypes`, the sensitive info types), then measures the AI/Copilot interaction activity and SharePoint/OneDrive broad-sharing signal from the audit log (RecordType/Operations parameterized). Writes `AI Access Scope – Estate – Discovery`, `Sensitive Exposure – Estate – Assess`, `AI Reachability – Copilot – Assess`, and `Oversharing Exposure – Sites – Assess`
`AIEXPOSE-RiskRegister.ps1`	Read-only reporting: scores and ranks the exposure findings (reachability breadth + no-lever penalty) into the prioritized `Exposure Risk Register – Estate – Rank`, each row with Score, Rationale, and suggested fix family. Reads only local CSVs

Script	What it does
`AIEXPOSE-PilotRemediation.ps1`	Configuration/remediation fix-path validation helper. Defaults to `-WhatIf`; with `-Commit` creates an auto-labeling policy in **simulation** (`Exposure Remediation – Pilot – Simulation`, labels nothing), or produces the prioritized sharing-restriction target list — **never enforces**
`AIEXPOSE-Validate.ps1`	Read-only validation: confirms all expected exports exist and are consistent (scope check, discovery, reachability, oversharing, and a descending-ranked register) and that any pilot policy is in **simulation** mode. Writes `AIEXPOSE Validate – Estate – Assess`

What the buyer receives

- This implementation guide as a branded **Word** document and **PDF**.
- All five **PowerShell scripts** in a single ZIP.
- A repeatable process following the model: **Assess → Design → Configure → Pilot (simulate) → Validate →

Expand (enforce, handed off)**.

Outcome

AI data exposure made **visible, quantified, and defensible**: the AI access surface inventoried, what Copilot/AI could reach measured, the priority risks scored and ranked into a register, and the recommended fix path validated in **simulation** — every step read-only or simulation, changing no content — so an organization can make an informed, evidenced decision about AI adoption. Turning the validated fix into an enforced reduction program is a scoped follow-on. Regulatory, records, and legal determinations remain with the organization's governance functions; this solution delivers the technical method and the evidence.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

AIEXPOSE-Discovery.ps1

Purpose: Read-only discovery for the AI Data-Exposure Assessment. Two halves of the exposure picture: (1) the ACCESS SURFACE that bounds what could be exposed — sensitivity labels, the label policies that publish them, DLP policies/rules, auto-labeling policies, and (with -IncludeSensitiveTypes) the sensitive information types in scope; and (2) REACHABILITY — the SharePoint/OneDrive broad- sharing signal (content Copilot can surface to anyone with access) and the AI/Copilot interaction activity from the unified audit log (what AI has actually touched, where in use). Changes nothing. HOW TO RUN PowerShell 5.1+ or 7+. Connect Security & Compliance PowerShell (access surface) and, for the reachability signal, Exchange Online (unified audit log) and optionally Graph: Connect-IPPSSession Connect-ExchangeOnline .\AIEXPOSE-Discovery.ps1 .\AIEXPOSE-Discovery.ps1 -IncludeSensitiveTypes -Days 30 The AI-interaction RecordType and sharing Operations evolve — override with -AiRecordType / -SharingOperations if your tenant differs (see .NOTES). EXPECTED RESULTS Access-surface inventory to .\AIEXPOSE-AccessScope-Estate-Discovery.csv (AI Access Scope - Estate - Discovery); with -IncludeSensitiveTypes, the sensitive-info-type list to .\AIEXPOSE-SensitiveExposure-Estate-Assess.csv (Sensitive Exposure - Estate - Assess); the AI- interaction summary to .\AIEXPOSE-Reachability-Copilot-Assess.csv (AI Reachability - Copilot - Assess); and broad-sharing events grouped by site to .\AIEXPOSE-Oversharing-Sites-Assess.csv (Oversharing Exposure - Sites - Assess). A thin taxonomy/narrow DLP is itself the first finding; pre-adoption, the AI-interaction set may legitimately be empty while oversharing is still present. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. Cmdlets/Graph calls are standard Security & Compliance PowerShell / Exchange Online / Graph; none are invented. Feature availability (auto-labeling, advanced DLP) is licensing-dependent — the script warns where a feature is not readable rather than assuming. VERIFY IN YOUR TENANT: the audit RecordType that surfaces AI/Copilot interactions and the sharing Operations both evolve — this script uses common defaults and lets you override them, rather than asserting them. Audit data has ingestion latency; very recent activity may not appear. > [CmdletBinding()] param([switch]$IncludeSensitiveTypes, [int]$Days = 30, [string]$AiRecordType = "CopilotInteraction", [string[]]$SharingOperations = @("SharingSet","AnonymousLinkCreated","AddedToGroup","SharingInvitationCreated"), [string]$OutPath = ".\AIEXPOSE-AccessScope-Estate-Discovery.csv", [string]$SensitiveOutPath = ".\AIEXPOSE-SensitiveExposure-Estate-Assess.csv", [string]$AiOutPath = ".\AIEXPOSE-Reachability-Copilot-Assess.csv", [string]$SharingOutPath = ".\AIEXPOSE-Oversharing-Sites-Assess.csv")

How to run: PowerShell 5.1+ or 7+. Connect Security & Compliance PowerShell (access surface) and, for the reachability signal, Exchange Online (unified audit log) and optionally Graph: Connect-IPPSSession Connect-ExchangeOnline .\AIEXPOSE-Discovery.ps1 .\AIEXPOSE-Discovery.ps1 -IncludeSensitiveTypes -Days 30 The AI-interaction RecordType and sharing Operations evolve — override with -AiRecordType / -SharingOperations if your tenant differs (see .NOTES). EXPECTED RESULTS Access-surface inventory to .\AIEXPOSE-AccessScope-Estate-Discovery.csv (AI Access Scope - Estate - Discovery); with -IncludeSensitiveTypes, the sensitive-info-type list to .\AIEXPOSE-SensitiveExposure-Estate-Assess.csv (Sensitive Exposure - Estate - Assess); the AI- interaction summary to .\AIEXPOSE-Reachability-Copilot-Assess.csv (AI Reachability - Copilot - Assess); and broad-sharing events grouped by site to .\AIEXPOSE-Oversharing-Sites-Assess.csv (Oversharing Exposure - Sites -

Assess). A thin taxonomy/narrow DLP is itself the first finding; pre-adoption, the AI-interaction set may legitimately be empty while oversharing is still present. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. Cmdlets/Graph calls are standard Security & Compliance PowerShell / Exchange Online / Graph; none are invented. Feature availability (auto-labeling, advanced DLP) is licensing-dependent — the script warns where a feature is not readable rather than assuming. VERIFY IN YOUR TENANT: the audit RecordType that surfaces AI/Copilot interactions and the sharing Operations both evolve — this script uses common defaults and lets you override them, rather than asserting them. Audit data has ingestion latency; very recent activity may not appear. > [CmdletBinding()] param([switch]$IncludeSensitiveTypes, [int]$Days = 30, [string]$AiRecordType = "CopilotInteraction", [string[]]$SharingOperations = @("SharingSet","AnonymousLinkCreated","AddedToGroup","SharingInvitationCreated"), [string]$OutPath = ".\AIEXPOSE-AccessScope-Estate-Discovery.csv", [string]$SensitiveOutPath = ".\AIEXPOSE-SensitiveExposure-Estate-Assess.csv", [string]$AiOutPath = ".\AIEXPOSE-Reachability-Copilot-Assess.csv", [string]$SharingOutPath = ".\AIEXPOSE-Oversharing-Sites-Assess.csv")

AIEXPOSE-PilotRemediation.ps1

Purpose: Proves the recommended remediation PATH for a priority exposure risk WITHOUT changing content or enforcing anything — the assessment's "pilot in simulation" step. Depending on -Action it either creates an AUTO-LABELING policy in SIMULATION mode (evaluates and reports what it WOULD label, applies nothing) so you can validate that labeling would land on the right content, or produces a prioritized SHARING-restriction target list from the risk register for site owners to act on. SAFE BY DEFAULT: prints intended actions under -WhatIf; creates the simulation policy only with -Commit; NEVER enforces. Turning a validated fix into an enforced program is a follow-on engagement, not this assessment. HOW TO RUN PowerShell 5.1+ or 7+ with Security & Compliance PowerShell (Connect-IPPSSession). Dry-run (default, no change): .\AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -WhatIf Create the SIMULATION validation policy (labels nothing): .\AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -Commit Produce the sharing-restriction target list from the register (no S&C session needed): .\AIEXPOSE-PilotRemediation.ps1 -Action SharingTargets -RiskRegisterCsv .\AIEXPOSE-RiskRegister-Estate-Rank.csv EXPECTED RESULTS AutoLabelSim: a named policy in SIMULATION mode exists (confirm in portal; Testing Test 8), labels nothing. SharingTargets: .\AIEXPOSE-SharingTargets.csv of prioritized sites for site-owner review. Nothing is created without -Commit; nothing is ever enforced by this script. .NOTES White-label Microsoft Purview tooling. SAFE-by-default (-WhatIf); simulation-only. No credentials stored. HIGH-IMPACT changes are piloted in simulation per the category model — this script validates the fix path and DOES NOT enforce; enforcement/expansion is a separate change-controlled follow-on. This helper does not change SharePoint sharing directly (SharingTargets only produces the list); apply restrictions via site owners / the portal / SharePoint Advanced Management under change control. Determinations (whether to remediate) remain with compliance/records/privacy/legal. No cmdlets invented. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([Parameter(Mandatory = $true)] [ValidateSet("AutoLabelSim","SharingTargets")] [string]$Action,

How to run: PowerShell 5.1+ or 7+ with Security & Compliance PowerShell (Connect-IPPSSession). Dry-run (default, no change): .\AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -WhatIf Create the SIMULATION validation policy (labels nothing): .\AIEXPOSE-PilotRemediation.ps1 -Action AutoLabelSim -SensitivityLabel "Confidential" -Commit Produce the sharing-restriction target list from the register (no S&C session needed):

.\AIEXPOSE-PilotRemediation.ps1 -Action SharingTargets -RiskRegisterCsv .\AIEXPOSE-RiskRegister-Estate-Rank.csv EXPECTED RESULTS AutoLabelSim: a named policy in SIMULATION mode exists (confirm in portal; Testing Test 8), labels nothing. SharingTargets: .\AIEXPOSE-SharingTargets.csv of prioritized sites for site-owner review. Nothing is created without -Commit; nothing is ever enforced by this script. .NOTES White-label Microsoft Purview tooling. SAFE-by-default (-WhatIf); simulation-only. No credentials stored. HIGH-IMPACT changes are piloted in simulation per the category model — this script validates the fix path and DOES NOT enforce; enforcement/expansion is a separate change-controlled follow-on. This helper does not change SharePoint sharing directly (SharingTargets only produces the list); apply restrictions via site owners / the portal / SharePoint Advanced Management under change control. Determinations (whether to remediate) remain with compliance/records/privacy/legal. No cmdlets invented. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([Parameter(Mandatory = $true)] [ValidateSet("AutoLabelSim","SharingTargets")] [string]$Action,

AIEXPOSE-RiskRegister.ps1

Purpose: Read-only reporting step. Reads the discovery inventory and the reachability exports and produces the ranked Exposure Risk Register — the assessment's core deliverable. Each finding gets a transparent, deterministic exposure score (reachability breadth x sensitivity signal) so the priority risks — broadly-shared sites/content most likely to hold sensitive data that Copilot can surface — sort to the top. The score is DECISION SUPPORT, not a determination: which risks to remediate and what exposure level is acceptable are deferred to compliance/records/privacy/legal. Changes nothing. HOW TO RUN PowerShell 5.1+ or 7+ (no live connection needed; reads the CSVs the prior scripts wrote): .\AIEXPOSE-RiskRegister.ps1 .\AIEXPOSE-RiskRegister.ps1 -OversharingCsv .\AIEXPOSE-Oversharing-Sites-Assess.csv -DiscoveryCsv .\AIEXPOSE-AccessScope-Estate-Discovery.csv EXPECTED RESULTS The ranked register written to .\AIEXPOSE-RiskRegister-Estate-Rank.csv (Exposure Risk Register - Estate - Rank), highest exposure first, each row with a Score, a Rationale, and a suggested fix family (label / DLP-for-AI / restrict sharing) for stakeholder review. Empty inputs yield an empty register (a valid pre-adoption result), not an error. .NOTES White-label Microsoft Purview tooling. Read-only; reads only local CSVs from the prior scripts. No credentials stored. The scoring weights are transparent parameters you can tune — they rank findings for human review; they do NOT decide remediation. No cmdlets are invented. > [CmdletBinding()] param([string]$OversharingCsv = ".\AIEXPOSE-Oversharing-Sites-Assess.csv", [string]$DiscoveryCsv = ".\AIEXPOSE-AccessScope-Estate-Discovery.csv", [string]$OutPath = ".\AIEXPOSE-RiskRegister-Estate-Rank.csv", [int]$BroadShareWeight = 5, # weight per broad-share event (reachability breadth) [int]$NoDlpPenalty = 20 # added exposure when no DLP lever exists to protect content)

How to run: PowerShell 5.1+ or 7+ (no live connection needed; reads the CSVs the prior scripts wrote): .\AIEXPOSE-RiskRegister.ps1 .\AIEXPOSE-RiskRegister.ps1 -OversharingCsv .\AIEXPOSE-Oversharing-Sites-Assess.csv -DiscoveryCsv .\AIEXPOSE-AccessScope-Estate-Discovery.csv EXPECTED RESULTS The ranked register written to .\AIEXPOSE-RiskRegister-Estate-Rank.csv (Exposure Risk Register - Estate - Rank), highest exposure first, each row with a Score, a Rationale, and a suggested fix family (label / DLP-for-AI / restrict sharing) for stakeholder review. Empty inputs yield an empty register (a valid pre-adoption result), not an error. .NOTES White-label Microsoft Purview tooling. Read-only; reads only local CSVs from the prior scripts. No credentials stored. The scoring weights are transparent parameters you can tune — they rank findings for human review; they do NOT decide remediation. No cmdlets are invented. > [CmdletBinding()] param(

[string]$OversharingCsv = ".\AIEXPOSE-Oversharing-Sites-Assess.csv", [string]$DiscoveryCsv = ".\AIEXPOSE-AccessScope-Estate-Discovery.csv", [string]$OutPath = ".\AIEXPOSE-RiskRegister-Estate-Rank.csv", [int]$BroadShareWeight = 5, # weight per broad-share event (reachability breadth) [int]$NoDlpPenalty = 20 # added exposure when no DLP lever exists to protect content)

AIEXPOSE-ScopeCheck.ps1

Purpose: Read-only pre-flight for an AI Data-Exposure Assessment. Confirms your Security & Compliance PowerShell (and optional Graph) sign-in, reports whether unified auditing is on (the source of AI-interaction signal), and enumerates the licensing-dependent controls (sensitivity labels, DLP, auto-labeling) and the DSPM-for-AI / Copilot presence that the assessment measures against. Changes nothing. HOW TO RUN PowerShell 5.1+ or 7+, with the ExchangeOnlineManagement (Security & Compliance PowerShell) and, optionally, Microsoft.Graph modules: Connect-IPPSSession .\AIEXPOSE-ScopeCheck.ps1 To also probe Graph (used later for the reachability/sharing signal), pass -UseGraph (Connect-MgGraph is invoked read-only). EXPECTED RESULTS A readiness summary: sign-in OK, auditing on/off, and counts of labels / DLP / auto-labeling artifacts present, plus whether Copilot/AI audit records are visible. Written to .\AIEXPOSE-ScopeCheck-Estate-Assess.csv. Resolves Requirements 2.1-2.4. Any FAIL must be resolved before assessing. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials are stored or requested in code. Availability caveat: DSPM for AI blades and feature availability are licensing-/tenant-dependent and evolving — this script reports the controls it can see; confirm DSPM-for-AI visibility in the Purview portal. Cmdlets used are standard Security & Compliance PowerShell / Graph; none are invented. > [CmdletBinding()] param([switch]$UseGraph, [string]$OutPath = ".\AIEXPOSE-ScopeCheck-Estate-Assess.csv")

How to run: PowerShell 5.1+ or 7+, with the ExchangeOnlineManagement (Security & Compliance PowerShell) and, optionally, Microsoft.Graph modules: Connect-IPPSSession .\AIEXPOSE-ScopeCheck.ps1 To also probe Graph (used later for the reachability/sharing signal), pass -UseGraph (Connect-MgGraph is invoked read-only). EXPECTED RESULTS A readiness summary: sign-in OK, auditing on/off, and counts of labels / DLP / auto-labeling artifacts present, plus whether Copilot/AI audit records are visible. Written to .\AIEXPOSE-ScopeCheck-Estate-Assess.csv. Resolves Requirements 2.1-2.4. Any FAIL must be resolved before assessing. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials are stored or requested in code. Availability caveat: DSPM for AI blades and feature availability are licensing-/tenant-dependent and evolving — this script reports the controls it can see; confirm DSPM-for-AI visibility in the Purview portal. Cmdlets used are standard Security & Compliance PowerShell / Graph; none are invented. > [CmdletBinding()] param([switch]$UseGraph, [string]$OutPath = ".\AIEXPOSE-ScopeCheck-Estate-Assess.csv")

AIEXPOSE-Validate.ps1

Purpose: Read-only validation for the AI Data-Exposure Assessment. Confirms the assessment deliverables exist and are internally consistent (scope check, discovery, reachability, and the ranked risk register), and — if a pilot remediation policy was created — confirms it is in SIMULATION mode and enforces nothing. This is the evidence gate that the assessment is defensible and that the fix path was validated WITHOUT changing content. Changes nothing. HOW TO RUN PowerShell 5.1+ or 7+. Connect Security & Compliance PowerShell to verify the pilot policy mode: Connect-IPPSSession .\AIEXPOSE-Validate.ps1 .\AIEXPOSE-Validate.ps1 -SimPolicyName "Exposure Remediation - Pilot - Simulation" EXPECTED RESULTS A pass/fail validation summary to .\AIEXPOSE-Validate-Estate-Assess.csv. All expected exports present = the assessment is complete; a

pilot policy, if present, reports Mode = simulation (TestWithoutNotifications) = PASS. Any policy found in an enforcing mode is a FAIL to correct. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. This validates evidence and the simulation-only posture; it does not enforce or change anything. No cmdlets are invented. > [CmdletBinding()] param([string]$ScopeCheckCsv = ".\AIEXPOSE-ScopeCheck-Estate-Assess.csv", [string]$DiscoveryCsv = ".\AIEXPOSE-AccessScope-Estate-Discovery.csv", [string]$ReachabilityCsv= ".\AIEXPOSE-Reachability-Copilot-Assess.csv", [string]$OversharingCsv = ".\AIEXPOSE-Oversharing-Sites-Assess.csv", [string]$RiskRegisterCsv= ".\AIEXPOSE-RiskRegister-Estate-Rank.csv", [string]$SimPolicyName = "Exposure Remediation - Pilot - Simulation", [string]$OutPath = ".\AIEXPOSE-Validate-Estate-Assess.csv")

How to run: PowerShell 5.1+ or 7+. Connect Security & Compliance PowerShell to verify the pilot policy mode: Connect-IPPSSession .\AIEXPOSE-Validate.ps1 .\AIEXPOSE-Validate.ps1 -SimPolicyName "Exposure Remediation - Pilot - Simulation" EXPECTED RESULTS A pass/fail validation summary to .\AIEXPOSE-Validate-Estate-Assess.csv. All expected exports present = the assessment is complete; a pilot policy, if present, reports Mode = simulation (TestWithoutNotifications) = PASS. Any policy found in an enforcing mode is a FAIL to correct. .NOTES White-label Microsoft Purview tooling. Read-only. No credentials stored. This validates evidence and the simulation-only posture; it does not enforce or change anything. No cmdlets are invented. > [CmdletBinding()] param([string]$ScopeCheckCsv = ".\AIEXPOSE-ScopeCheck-Estate-Assess.csv", [string]$DiscoveryCsv = ".\AIEXPOSE-AccessScope-Estate-Discovery.csv", [string]$ReachabilityCsv= ".\AIEXPOSE-Reachability-Copilot-Assess.csv", [string]$OversharingCsv = ".\AIEXPOSE-Oversharing-Sites-Assess.csv", [string]$RiskRegisterCsv= ".\AIEXPOSE-RiskRegister-Estate-Rank.csv", [string]$SimPolicyName = "Exposure Remediation - Pilot - Simulation", [string]$OutPath = ".\AIEXPOSE-Validate-Estate-Assess.csv")